

SCC.354 Coursework Report

Section 1: Outline

Introduction

This report analyses the CSVI datasets to assess and prioritise vulnerability risk across six UK sectors and fifty organisations. The purpose is to produce a defensible, time-efficient assessment that supports strategic decision-making (stakeholder view) and technical validation (analyst view). Results are derived solely from the provided CSVI documents and include clear limitations where data completeness or field inconsistencies constrain confidence.

Task context

The dataset describes a baseline of vulnerabilities across six sectors and fifty organisations, where risk is assessed at organisation level and summarised to sector level for comparison. This analysis treats risk as multidimensional rather than as a single score, separating exposure scale (volume of CVEs), vulnerability intensity (severity/ likelihood), exploitation evidence and remediation hygiene. Severity is represented by CVSS (NIST, 2024), likelihood by EPSS (First, 2026) and exploitation evidence by KEV (CISA, 2026). Remediation feasibility is interpreted using patch availability and a derived unpatched-known rate computed only where patch status is known (to avoid unknown values diluting the hygiene signal). A derived priority score (combining CVSS and EPSS to reflect severity and likelihood) is used to support ranking and comparison (Shimizu & Hashimoto, 2025). “At-Risk” is defined explicitly using 95th-percentile thresholds on organisation-level exposure (priority), exploitation burden (KEV count per organisation) and hygiene (unpatched-known rate) (Souppaya & Scarfone, 2022) with hygiene evaluated only when known-patch coverage is greater than or equal to 50%. Organisations are flagged if they exceed the threshold on any dimension.

Analytical Objectives

Quantify and compare sector exposure, identifying the most at risk and most resilient sectors based on organisational-level evidence aggregated to sector summaries. Organisations that warrant prioritised attention will be identified using an explicit at-risk rule grounded in exposure, exploitation evidence and patch hygiene signals. Vulnerabilities will be prioritised by combining severity and likelihood signals (CVSS and EPSS) and contextualising them with exploitation evidence (KEV) and patch availability. Vulnerabilities will be grouped using an advanced analytical method (KMeans) at CVE-level on CVSS and EPSS to identify severity-likelihood clusters (Movahedi, et al., 2017). Co-occurrence of CVEs at organisation level will be calculated to find common pairs (Ruohonen, et al., 2016). The results will be communicated in two forms: a non-technical stakeholder brief focused on decisions and quick wins, and a technical analysis report detailing methods, evidence and limitations.

Initial Plan Outline

Ingest and validate the two CSVI inputs, then normalise field formats to ensure consistent downstream computation. Then the data will be transformed into an analysis ready structure for organisation-CVE so organisation level metrics can be derived, these include exposure scale, intensity, exploitation evidence and hygiene. EDA will be performed to summarise the distributions and sector differences for CVSS, EPSS, KEV prevalence and patch availability

which will highlight data constraints that will affect conclusions. The at-risk rule is applied using 95th-percentile thresholds over exposure (priority), exploitation concentration (KEV count per organisation), and hygiene (unpatched known-rate) producing ranked sector organisation and CVE outputs. KMeans will be applied at CVE-level using the standardised features (CVSS, EPSS) to group vulnerabilities by severity-likelihood profile. The number of clusters will be selected using the silhouette score with inertia plotted as a supporting diagnostic. Cluster centroids will be used to identify the highest severity/likelihood group, from which a top-10 CVE shortlist will be extracted using the defined priority score. The final outputs required will be produced, sector exposure comparisons, at-risk organisations, prioritised CVEs, cross-sector patterns and a clear statement of limitations and their impact.

Section 2: EDA

In-depth Plan & Steps Taken

Data was collected from two inputs one which detailed the sector, organisation and CVE lists, and another which was a CVE attribute table that listed the CVSS, EPSS, KEV, patch, attack vector and attack complexity.

The sector-organisation list is flattened into a singular long format organisation-CVE dataset to enable consistent aggregation. Baseline dataset size checks are recorded to ensure downstream outputs are reproducible. Data integrity checks are run before any scoring or aggregation to prevent silent errors from occurring. Duplicate CVEs in the attribute table are checked (0 observed); CVE ID strings are validated against expected format (0 invalid observed); invalid CVSS and EPSS scores are checked (1 CVSS over threshold) and join coverage is measured to identify outlying CVEs that are present in organisation lists but missing attribute records (2 observed). The out-of-range CVSS value is set to NaN while keeping the record to avoid biasing exposure counts. The two CVEs missing attribute records (CVE-3022-71967 and CVE-2022-12003) are explicitly tracked rather than dropped and are excluded from attribute-based averages but still counted in exposure volume.

Categorical fields are normalised into controlled vocabularies to avoid inconsistent labels fragmenting counts and rates. Attack vector was standardised to Network/Adjacent/Local/Physical; patch availability was standardised to y/n/Unknown; and KEV was coerced to a binary 0/1 indicator. Attack vector and attack complexity were normalised but excluded from the analytical model, as these factors are already incorporated within the CVSS base score. Post-normalisation value counts are computed to confirm that standardisation worked as expected and to describe the data set composition. Numeric fields (CVSS/EPSS) are coerced to numeric types and summarised with descriptive statistics (mean, median, min/max) to establish baseline severity and likelihood characteristics across the CVE set.

Organisation-level metrics are derived from the joined organisation-CVE data set to capture different risk dimensions. Exposure scale (CVE count), vulnerability intensity (mean CVSS/EPSS and any derived priority score), exploitation evidence (KEV count/ KEV rate), remediation hygiene (patch availability, known patch coverage, un-patched known rate). Sector level summaries are produced by aggregating organisational metrics within each sector to enable cross-sector comparison.

EDA outputs include distributions of CVSS and EPSS, counts of KEV vs non-KEV, patch availability distributions and sector summary tables to support the later prioritisation and clustering analysis.

Issues encountered & Remediations applied

Patch availability inconsistencies as patch status appeared in multiple forms with “Unknown”. Patch availability was normalised into a controlled vocabulary (y/n/Unknown). Post-normalisation value counts were produced to quantify the patch category distribution. Patch-based rates used in organisation hygiene are computed on patch-known values to avoid “Unknown” diluting the signal.

Invalid and out-of-range fields where values exceeded the valid range or where identifiers did not have matching attribute records after joining. Values exceeding the valid range were set to NaN while keeping the records so that exposure counts are not biased. CVEs missing attribute records were retained in the organisation-CVE dataset for exposure volume but excluded from attribute-based rates and averages by filtering to known/valid attribute rows.

Fields containing inconsistent encodings that would fragment counts were identified and standardised. This occurred for patch availability, attack vector and KEV. Value counts were recomputed after normalisation to validate the standardisation succeeded. Whitespace was stripped to allow consistent parsing and aggregation.

Missing data and category distributions were quantified to interpret downstream metrics correctly. A data quality summary was generated reporting missing rates for key fields and frequency counts for categories, alongside join coverage statistics.

Dataset integrity checks were performed for potential duplicate CVE rows in the attribute table. Duplicates were counted and CVE strings were validated and valid-but-missing cases were quantified and displayed.

Presentation of data

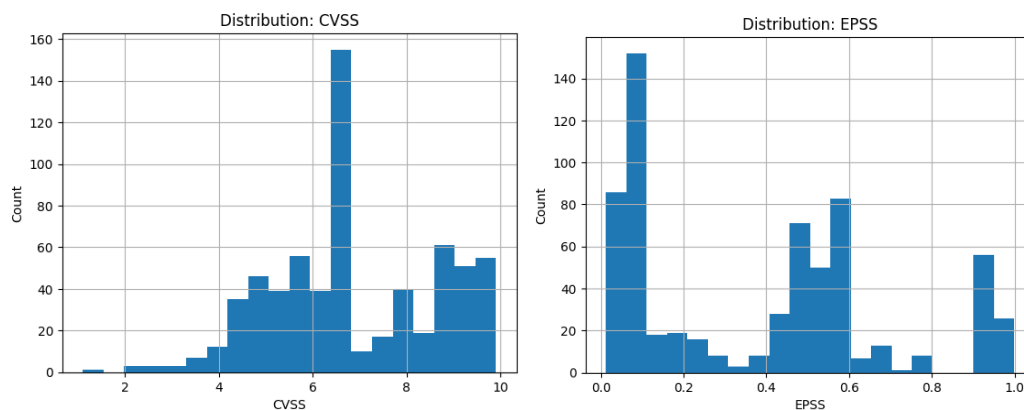


Figure 1- Distribution of CVSS Scores (Count of CVEs) Figure 2- Distribution of EPSS scores (Count of CVEs)

CVSS is a severity score that indicates the potential impact and exploit conditions of a vulnerability. Higher values represent greater severity on a 0-10 scale (NIST, 2024). EPSS is a likelihood score estimating the probability of an exploitation on a 0-1 scale, where higher values indicate higher likelihood (First, 2026). Figures 1-2 present the CVE-level distributions of both measures across the dataset. CVSS values are concentrated in the mid-to-high range with an upper tail approaching 10. This indicates that many recorded vulnerabilities are at least moderate severity with a subset of high severity. EPSS is skewed, with many vulnerabilities assigned low likelihood scores with a smaller set of scores both around 0.1 and 1.0. Any out-of-range values were set to NaN and excluded from these plots to avoid distorting the distribution.

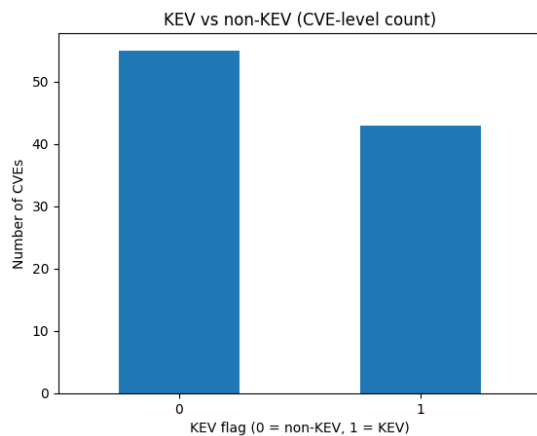


Figure 3 - KEV vs non-KEV (CVE-level count)

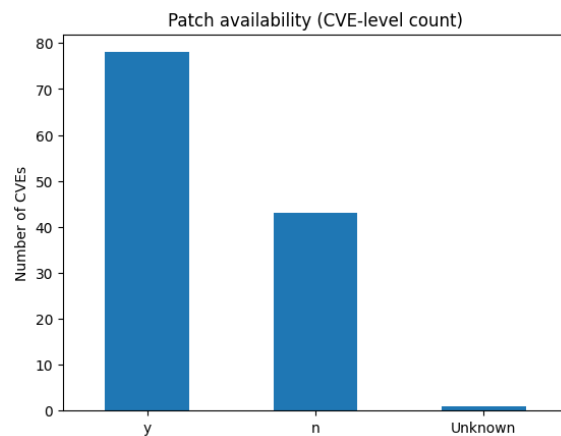


Figure 4 – Patch Availability (CVE-level count)

Known exploited vulnerabilities (KEV) is a binary indicator of exploitation evidence. A value of 1 indicates the CVE is listed as known exploited (CISA, 2026). Figure 3 shows CVE-level counts, de-duplicated by CVE to avoid double counting across organisations. Non-KEV CVEs are more common than KEV CVEs, however the KEV subset indicates confirmed exploitation relevance. Patch availability indicates whether a known fix is available for the CVE. “y” indicates a patch is available, “n” indicates there is not and “Unknown” indicates patch status was not provided. Figure 4 is a CVE-level count from the attribute table. “y” takes up the majority, indicating most CVEs in the dataset have a patch available. Organisation-level patch-based rates later use known patch values (y/n) to prevent “Unknown” entries diluting the estimates.

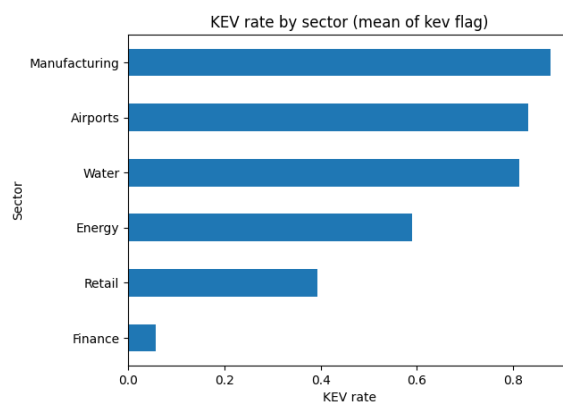


Figure 5 - Mean KEV rate plotted against Sector

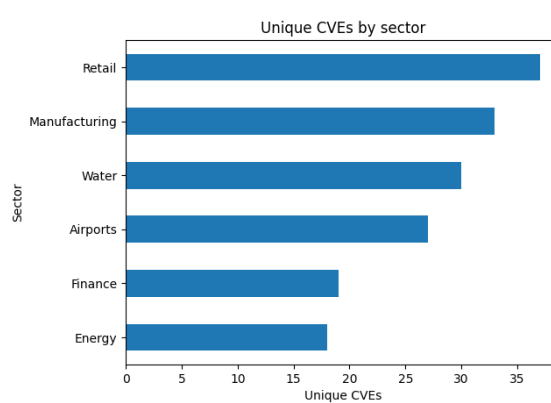


Figure 6 - Unique CVEs by Sector

Figure 5 shows the mean of the binary KEV flag within each sector. This captures the exploitation evidence concentration within each sector, highlighting the sectors with the highest and lowest KEV rates. Manufacturing has the highest KEV rate closely followed by Airports and Water with Finance having the least. Figure 6 shows the number of unique CVEs observed in each sector, this captures exposure volume. Retail has the highest unique CVE count closely followed by manufacturing and water with Energy having the least. These dimensions are reported separately. Later sector technical analysis also reports a deduplicated CVE view to separate unique vulnerability prevalence from repeated organisation-CVE exposure frequency. Because sectors contain different numbers of organisations, exposure metrics are later evaluated at organisation-level as well as sector-level to avoid sector size bias.

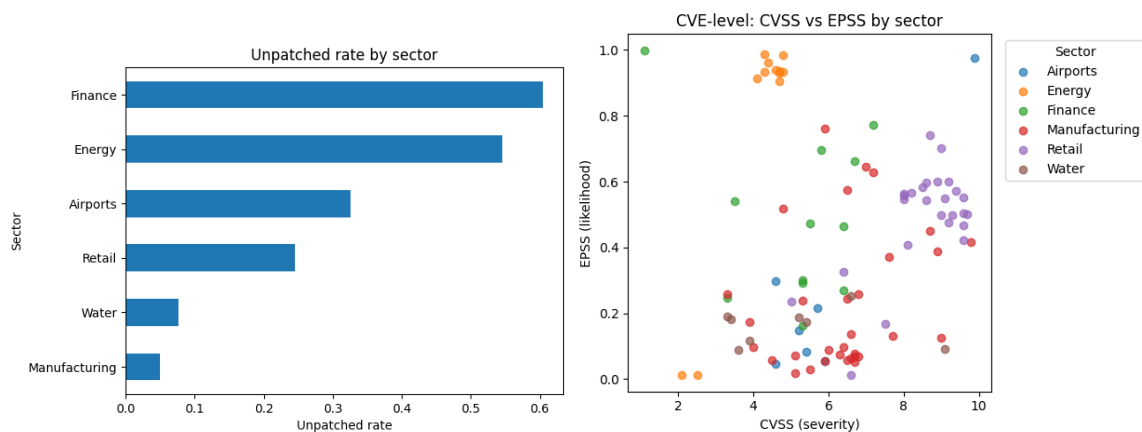


Figure 7 - Mean unpatched rate plotted against Sector

Figure 8 – CVSS vs EPSS plotted per sector

Figure 7 details the unpatched rate per sector which is the proportion of organisation-CVE records with no patch available within each sector. Finance has the highest unpatched rate with Energy closely following and Manufacturing has the lowest. Figure 8 shows CVE-level CVSS vs EPSS scatter with points coloured by sector, using CVE de-duplication to avoid double counting across organisations. The top-right region represents high severity and high likelihood; these are the highest priority. Airports include a high-severity, high-likelihood outlier, while Retail has a dense cluster of high-severity CVEs with moderate-to-high EPSS values. Sectors with higher unpatched rates and clusters of high CVSS/high EPSS CVEs are prioritised for deeper review in later risk scoring and clustering. The scatter indicates that severity and exploitation likelihood are not strongly aligned, meaning some moderate severity CVEs still have high exploitation probability. Using both CVSS and EPSS therefore avoids prioritisation based on severity or likelihood alone.

Section 3: Analysis Report

Technical analysis per sector

In the sector technical analysis, CVEs are deduplicated per sector (each CVE counted once).

Retail

- Exposure: 10 organisations; 37 unique CVEs; median organisation CVEs = 22 (Q1=22, Q3=22 so exposure is uniform across organisations).
- Severity/Likelihood: median CVSS 8.6 (high); median EPSS 0.5025 (moderate)
- KEV burden: 13 KEV CVEs; KEV rate 0.361 (moderate exploitation evidence proportionally)
- Hygiene: patch coverage 0.995; unpatched-known rate 0.246

Manufacturing

- Exposure: 14 organisations; 33 unique CVEs; median organisation CVEs = 13 (Q1=11.25, Q3=14 so exposure has moderate variation across organisations).
- Severity/Likelihood: median CVSS 6.5 (moderate-high); median EPSS 0.129 (low likelihood)
- KEV burden: 16 KEV CVEs; KEV rate 0.50 (high exploitation evidence proportionally).
- Hygiene: patch coverage 0.995; unpatched-known rate 0.050 (best hygiene)

Water

- Exposure: 9 organisations; 30 unique CVEs; median organisation CVEs = 11 (Q1=7, Q3=14 so wider spread between organisations)
- Severity/Likelihood: median CVSS 6.45 (moderate-high); median EPSS 0.122 (low likelihood)

- KEV burden: 15 KEV CVEs; KEV rate 0.50 (high exploitation evidence proportionally).
- Hygiene: patch coverage 1.0; unpatched-known rate 0.109

Airports

- Exposure: 7 organisations; 27 unique CVEs; median organisation CVEs = 13 (Q1=12, Q3=13.5 so exposure is uniform across organisations).
- Severity/Likelihood: median CVSS 5.2 (moderate); median EPSS 0.451 (moderate likelihood)
- KEV burden: 14 KEV CVEs; KEV rate 0.519 (high exploitation evidence proportionally).
- Hygiene: patch coverage 0.990; unpatched-known rate 0.327

Finance

- Exposure: 6 organisations; 19 unique CVEs; median organisation CVEs = 9.5 (Q1=7.5, Q3 =10 so exposure is roughly uniform across organisations).
- Severity/Likelihood: median CVSS 5.9 (moderate-high); median EPSS 0.466 (moderate)
- KEV burden: 2 KEV CVEs; KEV rate 0.105 (low exploitation evidence proportionally)
- Hygiene: patch coverage 1.0; unpatched-known rate 0.609 (worst hygiene)

Energy

- Exposure: 4 organisations; 18 unique CVEs; median organisation CVEs = 4 (Q1=3.75, Q3=5.75 so exposure is uniform across organisations).
- Severity/Likelihood: median CVSS 4.7 (moderate); median EPSS 0.9095 (very high likelihood)
- KEV burden: 13 KEV CVEs; KEV rate 0.722 (highest)
- Hygiene: patch coverage 1.0; unpatched-known rate 0.653 (poor hygiene)

Key Takeaways

Retail has the highest exposure (37 unique CVEs) and the highest severity baseline (median CVSS 8.6), indicating high impact potential at scale. Energy has a lower exposure volume (18 unique CVEs) but the highest exploitation evidence (KEV rate 0.722) and worst hygiene (mean unpatched-known rate 0.653), making it a high priority sector despite having fewer CVEs. Finance has relatively low exposure (19 unique CVEs) and low KEV burden (KEV rate 0.105) but poor remediation hygiene (unpatched-known rate 0.609), indicating patching risk where patch status is known. Manufacturing and Water show high KEV rates (0.50) but comparatively stronger hygiene (especially Manufacturing at 0.050 unpatched-known), suggesting exploitation relevance exists but remediation posture is better. Airports show moderately high exposure with moderate severity (median CVSS 5.2) but high KEV rate (0.519) and mid hygiene risk (0.327 unpatched-known).

Methods

Normalisation

CVSS was normalised as “ $cvss_norm = cvss / 10$ ”, while EPSS did not require normalisation (“ $epss_norm = epss$ ”).

Priority Score

Priority was calculated per organisation-CVE row with the following calculation “ $priority = 0.5 * cvss_norm + 0.5 * epss_norm$ ”. Equal weights were chosen to reflect a balanced operational stance, so vulnerabilities are prioritised when they are either highly damaging (high CVSS) and/or highly likely to be exploited (high EPSS) (Shimizu & Hashimoto, 2025). If either CVSS or EPSS is missing, then that term is treated as 0 in the sum. This allows for computation of a single continuous priority score for all records with the choice being intentionally conservative to avoid

artificially inflating risk when fields are unknown. This is due to the data being missing at random, although this introduces a bias the data missing is low, so it is a small bias.

KEV Rate

Per sector for EDA, “kev_rate_sector = mean(kev)” was computed across organisation-CVE rows within each sector. For organisation-level analysis “kev_rate_org = kev_count / cve_count” was used.

Patch Hygiene

“patch_known” is true when “patch_available” is “y” or “n”. “known_patch_coverage” is the proportion of organisation-CVE rows where “patch_known” is true. “is_unpatched” is true when “patch_available” = “n” (no patch is available) and “unpatched_known_rate” is the proportion of patch-known organisation-CVE with no patch available. CVEs listed for an organisation are treated as currently present vulnerabilities. Therefore, when “patch_available” is “y”, a patch exists and remediation is feasible, but the vulnerability remains present in the organisations exposure set.

In this report the hygiene signal captures remediation feasibility, a higher “unpatched_known_rate” indicates a larger share of present vulnerabilities where no patch is currently available. This requires a reliance on mitigation and indicates a weaker remediation posture (Souppaya & Scarfone, 2022).

Thresholding rules

An organisation-level flag if an organisation exceeds the 95th percentile on any dimension:

- **Exposure/intensity:** “sum_priority >= Q95(sum_priority)”
- **Exploitation burden:** “kev_count >= Q95(kev_count)”
- **Hygiene:** if “known_patch_coverage >= 0.5” then “unpatched_known_rate >= Q95(unpatched_known_rate)”

95th percentile thresholding creates a relative shortlist of the most extreme organisations without assuming fixed “safe” cuts offs. Using any dimension reduces the chances of missing organisations that are extreme in one risk axis but not in others. The “known_patch_coverage >= 0.5” eligibility rule prevents hygiene flags being driven by missing patch data. This supports focused review prioritisation.

Core Results

Table 1 At risk organisations flagged

	sector	organisation	cve_count	sum_priority	mean_priority	kev_count	known_patch_coverage	unpatched_known_rate	reason
37	Retail	Summit Retail Group	23	15.7645	0.685413	9.0	1.0	0.304348	risk_exposure
36	Retail	Redline Electronics	22	15.7165	0.714386	9.0	1.0	0.227273	risk_exposure
35	Retail	Nova Fashion House	23	15.5220	0.674870	10.0	1.0	0.217391	risk_exposure
0	Airports	Ashbourne Airport	13	8.6720	0.667077	13.0	1.0	0.307692	risk_exploited
30	Manufacturing	Titan Metalcraft	16	5.8910	0.368188	14.0	1.0	0.000000	risk_exploited
19	Manufacturing	Brightline Industrial	15	5.7315	0.382100	13.0	1.0	0.000000	risk_exploited
18	Manufacturing	BlueForge Industries	14	5.2085	0.372036	13.0	1.0	0.071429	risk_exploited
12	Finance	BlueRock Securities	7	3.6430	0.520429	0.0	1.0	0.714286	risk_hygiene
10	Energy	VoltStream Power	4	1.5580	0.389500	1.0	1.0	0.750000	risk_hygiene
7	Energy	Helios Energy Corp	3	0.6950	0.231667	0.0	1.0	1.000000	risk_hygiene

Table 1 lists organisations flagged as “at-risk” under the 95th-percentile thresholding rule detailed above in Methods using the exposure (sum_priority), exploitation (kev_count) and hygiene (unpatched_known_rate) dimensions. Retail entries are primarily flagged for risk_exposure (high sum_priority). Several Manufacturing and Airports entries are flagged for

risk_exploited (high kev_count). Finance and Energy entries are flagged for risk_hygiene (high unpatched_known_rate) despite lower exposure totals. All shown rows have known_patch_coverage = 1.0, so hygiene flags are based on fully known patch status. Overall, flags arise from different risk dimensions across sectors, supporting a multi-axis prioritisation rather than relying on exposure volume alone.

Clustering (KMeans)

KMeans clustering was selected as an interpretable unsupervised method suitable for highlighting natural groupings of CVEs by severity (CVSS) and likelihood (EPSS) to support prioritisation (Movahedi, et al., 2017). I chose KMeans due to it being fast, widely used and descriptive via 2D visualisation. Outputs are also easy to translate into operational labels. CVE-level (deduplicated by CVE, excluding entries missing CVSS or EPSS) was prioritised to avoid aggregation smearing before rolling up to sectors and organisations. CVSS and EPSS were used due to them representing the two core risks being impact and probability (Shimizu & Hashimoto, 2025). KEV and patch availability were excluded due to them being binary which can distort Euclidean distance clustering. Z-score standardisation was applied to prevent CVSS (0-10) dominating EPSS (0-1) in Euclidean distance calculations (Hastie, et al., 2017). k was selected by evaluating k=2-10; k=3 was chosen because silhouette reached its maximum at 3, with inertia showing diminishing returns past this point.

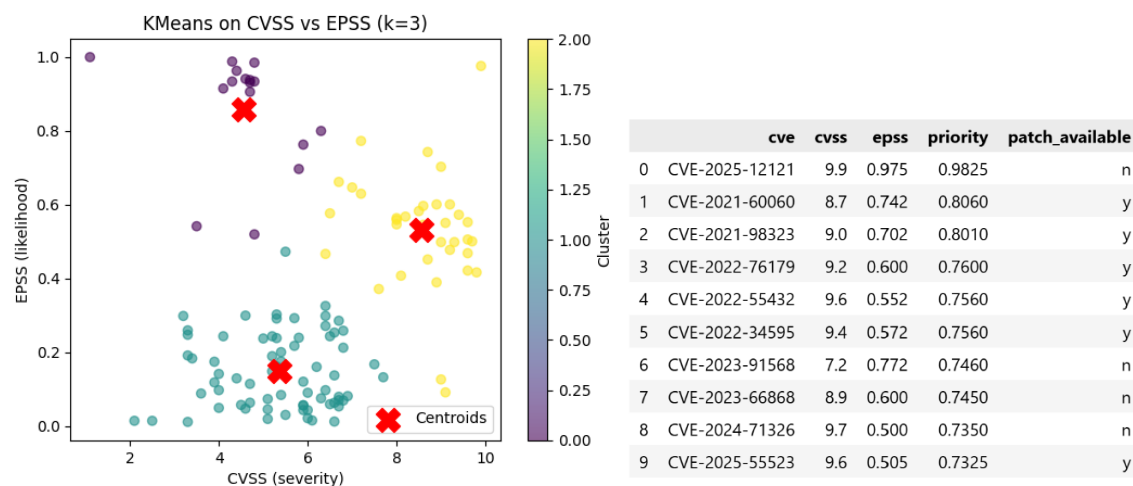


Figure 9 – KMeans clustering of CVSS vs EPSS

Table 2 – Top 10 CVEs based on priority score

Figure 9 shows KMeans clusters on CVE-level CVSS vs EPSS with k=3. The red Xs are cluster centroids, which represent the typical CVE profile per cluster. Cluster 0's centroid has CVSS=4.55 and EPSS=0.86. This is moderate severity with very high likelihood, meaning high exploitation probability despite lower impact. Cluster 1's centroid has CVSS= 5.36 and EPSS=0.15. This is mid severity with low likelihood, meaning lower exploitation-probability group. Cluster 2's centroid has CVSS=8.57 and EPSS=0.53. This is high severity with a moderate-high likelihood, meaning it has the highest operational risk profile. Cluster 2 is highest jointly across both CVSS and EPSS which makes it the highest risk.

Table 2 details the top 10 CVEs within cluster 2 (high severity with moderate to high likelihood). The CVEs were sorted by the priority score ($0.5 \times (\text{CVSS}/10) + 0.5 \times \text{EPSS}$). Many of the listed CVEs have high severity and high likelihood, meaning they combine high impact with meaningful exploitation probability.

Patterns/ Associations

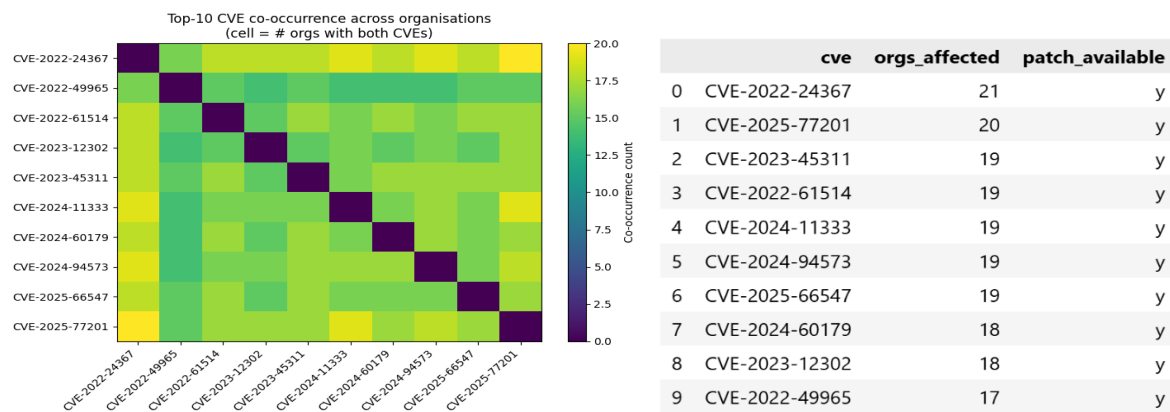


Figure 10 – Co-occurrence heatmap across organisations

Table 3 – Most common CVEs across organisations

Figure 10 is a heatmap of top-10 CVEs by prevalence with each cell indicating the number of organisations that contain both CVEs. Co-occurrence values are very high (mostly between 18-20) indicating these vulnerabilities appear together across many organisations. Key pairs are as follows: CVE-2022-24367 + CVE-2025-77201 occurs in 20 organisations (highest); CVE-2022-24367 + CVE-2024-94573 occurs in 19 organisations; CVE-2022-24367 + CVE-2024-11333 occurs in 19 organisations. This suggests a shared “common bundle” of vulnerabilities affecting many organisations (co-occurrence indicates co-presence, not causality). This suggests remediation of a small number of shared vulnerabilities could significantly reduce exposure.

Table 3 details the counts of how many organisations each CVE affects. The most widespread CVEs are CVE-2022-24367 which affects 21 organisations (most prevalent) and CVE-2025-77201 which affects 20 organisations with many others impacting 19. This high overlap means that prioritising mitigation for these few common CVEs yields broad risk reduction, because the fixes apply across many organisations/sectors (Ruohonen, et al., 2016).

Limitations

CVEs with missing CVSS or EPSS are excluded from CVSS-EPSS clustering and can weaken or shift priority rankings. KMeans results are sensitive to the chosen k. The small dataset size increases this sensitivity and reduces stability/generalisation. KMeans uses Euclidean distance and implicitly favours roughly spherical clusters; real vulnerability risk structures may not match this assumption. The Priority score uses equal weights ($0.5 \times (\text{CVSS}/10) + 0.5 \times \text{EPSS}$); different stakeholders may weight impact vs likelihood differently. Co-occurrence shows co-presence, not causality or shared root cause.

Section 4: Stakeholder brief

Summary of sector risk

Retail has the highest exposure volume (unique CVEs) and highest severity baseline. Energy has the highest exploitation evidence and worst hygiene. Finance has low exploitation evidence but poor hygiene. Manufacturing and Water show strong hygiene despite high KEV rates. Risk is distributed differently across sectors so no single metric should be used for prioritisation.

Immediate Priority:

- Retail: Largest exposure volume and highest severity baseline
- Energy: Highest KEV rate and worst hygiene (high no-patch rate) despite lower exposure.

Elevated Monitoring:

- Airports: High KEV rate and elevated hygiene risk (moderate-to-high no-patch rate).
- Finance: Lowest KEV rate but worst hygiene (high no-patch rate).

Strong Posture:

- Manufacturing: High KEV rate but best hygiene (low no-patch rate).
- Water: High KEV rate but good hygiene (low no-patch rate).

Key findings

Cross-Sector Risk Pattern

A small set of CVEs appear across most organisations (Table 3). CVE-2022-24367 affects 21 organisations. CVE-2025-77201 affects 20. Co-occurrence values of 18-20 indicate common bundles. This means a limited set of vulnerabilities drive cross-sector exposure. As shown in Table 3, the top-10 most prevalent CVEs all have patches available. Targeting these patchable, high-prevalence CVEs offers broad risk reductions across multiple organisations.

Priority Vulnerability Focus

High-severity CVEs with moderate-to-high exploitation likelihood represent the highest operational risk. The top-10 shortlist (Table 2) highlights these, with CVE-2025-12121 ranked highest. Prioritise CVEs with high CVSS and high EPSS where patches are known and the vulnerability is still present in the organisations exposure set. In Table 2, patch availability is listed as the final column. This enables rapid identification of high-priority CVEs with an available remediation path. For any high-priority CVEs with no known patch, mitigations should be prioritised and compensating controls should be applied to reduce risk.

“At-risk” organisations

Organisations are flagged “at risk” when they fall within the top 5% on any of three drivers: exposure, exploited or hygiene. Table 1 lists the organisations flagged by these rules, highlighting the worst cases across each risk dimension. Some findings align with sector analysis, such as retail organisations dominating exposure-driven risk. These organisations should be targeted first as they represent the highest-risk cases in the dataset.

Actionable quick wins

- Remediate the high-severity/high-likelihood shortlist (Table 2)
 - Treat Table 2 as the “highest operational risk” worklist and execute remediation in descending priority order focusing on available patches first.
- Fix the most common cross-sector CVEs (Table 3) to maximise risk reduction per fix
 - Prioritising the most prevalent CVEs maximises coverage. A small number of fixes reduces exposure across many organisations; Table 3 confirms patches are available for these top CVEs.
- Target top-10 at risk organisations (Table 1)
 - These organisations have been flagged as at risk and require immediate attention and remediating them will have a large impact.
- Focus remediation on immediate priority sectors
 - Retail has the highest exposure volume and severity baseline, while Energy shows the highest exploitation evidence and elevated hygiene risk.
- Improve patch status visibility and normalise reporting
 - This improves future prioritisation and remediation planning by increasing confidence in the underlying risk signals.

Bibliography

CISA, 2026. *Known Exploited Vulnerabilities Catalog*. [Online]
Available at: <https://www.cisa.gov/known-exploited-vulnerabilities-catalog>
[Accessed 6 3 2026].

First, 2026. *EPSS*. [Online]
Available at: <https://www.first.org/epss/>
[Accessed 6 3 2026].

Hastie, T., Tibshirani, R. & Friedman, J., 2017. *The Elements of Statistical Learning Data Mining, Inference, and Prediction*. Second Edition ed. s.l.:Springer.
[Accessed 6 3 2026].

Movahedi, Y., Cukier, M., Andongabo, A. & Gashi, I., 2017. *Cluster-based Vulnerability Assessment Applied to Operating Systems*, London: University of London.
[Accessed 6 3 2026].

NIST, 2024. *Vulnerability Metrics*. [Online]
Available at: <https://nvd.nist.gov/vuln-metrics/cvss>
[Accessed 6 3 2026].

Ruohonen, J., Holvitie, J., Hyrynsalmi, S. & Leppänen, V., 2016. *Exploring the Clustering of Software Vulnerability Disclosure Notifications Across Software Vendors*, Turku: University of Turku.
[Accessed 6 3 2026].

Shimizu, N. & Hashimoto, M., 2025. *VULNERABILITY MANAGEMENT CHAINING: AN INTEGRATED FRAMEWORK FOR EFFICIENT CYBERSECURITY RISK PRIORITIZATION*, Kagawa: Kagawa University .
[Accessed 6 3 2026].

Souppaya, M. & Scarfone, K., 2022. *Guide to Enterprise Patch Management Planning: Preventive Maintenance for Technology*, Gaithersburg: NIST.
[Accessed 6 3 2026].